

Additif à l'erratum — 7 octobre 2026

NBLogiTrack — corrections postérieures au 5 octobre (demande de fusion n° 120)

Après le 5 octobre 2026, l'application a reçu des corrections de sécurité issues d'un audit OWASP Top 10, fusionnées le 7 octobre ; les passages ci-dessous de l'erratum sont à lire ainsi.

La colonne « Page » renvoie aux pages imprimées de l'erratum du 5 octobre 2026 ; « N° » renvoie aux lignes de son tableau.

Page	Endroit	Au lieu de	Lire
Toutes	Les chiffres de l'erratum sont arrêtés au 5 octobre 2026. Au 7 octobre 2026 : 516 commits sur 27 jours de travail, 114 demandes de fusion, dont 110 fusionnées, 748 tests et 4 263 assertions. Ailleurs, un chiffre que l'erratum date explicitement du 5 octobre reste juste à cette date (ainsi p. 69, N° 100).		
1	Objet de l'erratum, 2 ^e paragraphe	« Le développement s'est poursuivi jusqu'au 5 octobre 2026. »	Le développement s'est poursuivi jusqu'au 7 octobre 2026.
2	Repères, en-tête de la 3 ^e colonne	« Erratum (5 octobre 2026) »	Erratum (5 octobre 2026, chiffres au 7 octobre selon l'additif)
2	Repères, ligne « Version de l'application », colonne « Erratum »	« v0.3.0-beta (publiée le 30 septembre 2026, étiquette reposée le 3 octobre), complétée jusqu'au 5 octobre »	v0.3.0-beta (publiée le 30 septembre 2026, étiquette reposée le 3 octobre), complétée jusqu'au 7 octobre
2	Repères, ligne « Historique du dépôt », colonne « Erratum »	« 508 commits, 26 jours de travail (au 5 octobre) »	516 commits, 27 jours de travail (au 7 octobre)
2	Repères, ligne « Tests automatisés », colonne « Erratum »	« 738 tests et 4 186 assertions, sur PostgreSQL »	748 tests et 4 263 assertions, sur PostgreSQL
4	Les principales corrections, point 10 « La réalisation », 1 ^{re} phrase	« 508 commits sur 26 jours de travail, 113 demandes de fusion, la version v0.3.0-beta (publiée le 30 septembre 2026), complétée jusqu'au 5 octobre, et 738 tests automatisés. »	516 commits sur 27 jours de travail, 114 demandes de fusion, la version v0.3.0-beta (publiée le 30 septembre 2026), complétée jusqu'au 7 octobre, et 748 tests automatisés.
13	Chapitre 5, N° 28, § 5, 3 ^e paragraphe, texte « Lire »	« ... et complétée jusqu'au 5 octobre 2026. La version décrite dans ce rapport correspond à l'état du dépôt au 5 octobre 2026, soit cinq cent huit commits sur la branche principale. »	... et complétée jusqu'au 7 octobre 2026. La version décrite dans ce rapport correspond à l'état du dépôt au 7 octobre 2026, soit cinq cent seize commits sur la branche principale.
25	Figure E9, branche « non » de « Compte actif et entreprise validée ? »	« Déconnecter et afficher le motif (désactivé, en attente, refusé) »	La case devient deux cases successives, « Enregistrer la connexion refusée au journal (compte désactivé, entreprise en attente, inscription refusée) » puis « Afficher le motif (désactivé, en attente, refusé) », car aucune session n'est ouverte à ce stade.
26	Figure E10, appel au Service Auth et fragment [Compte désactivé ou entreprise non validée]	« attempt(e-mail, mot de passe) » ... « logout() »	Le contrôleur vérifie l'e-mail et le mot de passe sous une temporisation commune (hachage leurre compris) sans ouvrir de session, « logout() » devient « enregistrer(auth.blocked) » vers le Service Journal, et la session n'est ouverte (login) qu'en cas d'authentification réussie, avant « effacer les essais ».
31	Figure E16, branches « Identité et e-mail », « Mot de passe » et « Supprimer mon compte »	« Mot de passe actuel correct ? (6 essais par minute) — non → Afficher l'erreur »	Le test « Mot de passe actuel correct ? » s'ajoute aussi aux branches « Mot de passe » et « Supprimer mon compte », et sur les trois branches sa sortie « non » passe par la case « Enregistrer le mot de passe erroné au journal (10 lignes par minute au plus) » avant « Afficher l'erreur ».

Page	Endroit	Au lieu de	Lire
32	Figure E17, fragment [Données invalides]	« erreurs par champ / 302 retour avec les erreurs »	Avant « erreurs par champ », le Service Validation inscrit « INSERT activity_logs (auth.password_rejected) » dans la base de données quand le mot de passe actuel est faux, et reçoit « ok ».
61-62	Chapitre 13, N° 77, point « Le tableau OWASP... »	« quatre campagnes d'audit, 738 tests rejoués »	quatre campagnes d'audit, 748 tests rejoués
69	Chapitre 16, N° 100, point sur les tests	« 738 tests et 4 186 assertions, dont 38 unitaires »	748 tests et 4 263 assertions, dont 38 unitaires
69	Chapitre 16, N° 101, § 16.1, texte « Lire »	« lance les 738 tests sur une base PostgreSQL 16 »	lance les 748 tests sur une base PostgreSQL 16
69	Chapitre 16, N° 102, § 16.3, texte « Lire »	« Au 5 octobre, la suite compte 738 tests et 4 186 assertions. »	Au 7 octobre, la suite compte 748 tests et 4 263 assertions.
71	Améliorations postérieures au dépôt, N° 104, point « Chaîne d'approvisionnement »	« ... actions épinglées par leur empreinte. »	Ajouter ensuite : « Dans le Dockerfile, l'installateur d'extensions PHP et Composer sont copiés depuis des images épinglées par leur empreinte SHA-256, et non plus téléchargés en version "latest" depuis GitHub. »
71	Améliorations postérieures au dépôt, N° 104, point « Cas réel du 3 octobre 2026 »	« ... qui laisse bloquante toute autre faille élevée ou critique. »	Ajouter ensuite : « Second cas réel, le 7 octobre 2026 : npm audit a fait échouer l'intégration continue sur shell-quote, source-map-js et postcss-selector-parser ; leurs versions corrigées sont imposées (overrides de package.json, package-lock.json) et la CI repasse. L'avis sur braces reste le seul écarté. »
72	Conclusion, N° 106, point « Chiffres à jour »	« 738 tests et 4 186 assertions au lieu de 88 tests »	748 tests et 4 263 assertions au lieu de 88 tests
72	Conclusion, N° 107, 2 ^e paragraphe, texte « Lire »	« une suite de 738 tests automatisés et 4 186 assertions »	une suite de 748 tests automatisés et 4 263 assertions

Corrections de sécurité du 7 octobre

Catégories selon la numérotation OWASP 2025 (Top 10:2025), celle que cite l'erratum.

A03 *Chaîne d'approvisionnement logicielle.* Dépendances npm : l'audit de l'intégration continue échouait sur shell-quote, source-map-js et postcss-selector-parser ; leurs versions corrigées sont imposées, le build est identique octet pour octet, et seul l'avis sur braces reste écarté et documenté. Image Docker : l'installateur d'extensions PHP (2.12.0) et Composer (2.10.3) sont copiés depuis des images épinglées par empreinte SHA-256, au lieu d'un téléchargement « latest » depuis GitHub.

A07 *Authentification.* Connexion : l'e-mail et le mot de passe sont vérifiés sous une temporisation commune, sans ouvrir de session, puis le compte est contrôlé avant l'ouverture de la session ; la réponse prend le même temps, que l'adresse ait un compte ou non (environ 270 ms, contre 440 ms et 240 ms auparavant).

A08 *Intégrité des logiciels et des données.* Ces mêmes images sont épinglées par leur empreinte : un contenu modifié arrête la construction de l'image Docker.

A09 *Journalisation et alertes.* Le journal d'activité inscrit en plus (1) les accès refusés (403, et refus « introuvable » sur l'expédition, la facture, le paiement, la demande d'accès API ou le collègue d'une autre entreprise) et (2) les mots de passe actuels erronés (confirmation, changement de mot de passe ou d'adresse, suppression du compte) : pour ces deux-là, au plus 10 lignes par minute par compte ou par adresse IP (JournalSecurite). (3) Les connexions refusées d'un compte désactivé, d'une inscription refusée ou d'une entreprise en attente (auth.blocked, avec le motif ; avant : connexion puis déconnexion) sont écrites par LoginRequest et bornées par la limite de connexion (5 essais par minute pour un couple adresse e-mail et IP), et non par la limite de 10 lignes.

Sans changement : A01, A02, A04, A05, A06, A10. La double authentification reste à faire.